



NC STATE
UNIVERSITY

NRP 
Nuclear Reactor Program

NE235 Nuclear Reactor Operations

Module #5 – Special Topic

Cyber-Security of Nuclear Plant Industrial Control Systems (ICS)

Dept. of Nuclear Engineering
North Carolina State University

Cyber-Security of Nuclear Plant Industrial Control Systems (ICS)

Outline

- ❑ Aurora Test – case study in what can happen.
- ❑ SCADA / ICS Networks – vs- IT Networks
- ❑ ICS Attack Vectors – “Kill Chain”
- ❑ Cyber Security – Defense in Depth
 - SSEP Function CDA (Critical Digital Asset) Audit
 - NIST and ICS-CERT Vulnerability Databases
 - Threat & Risk Assessment
- ❑ PULSTAR Case Review
- ❑ History of Cyber Attacks at NPP's and Industry Vulnerability Trends

Cyber-Security for Industrial Control Systems

Project Aurora:

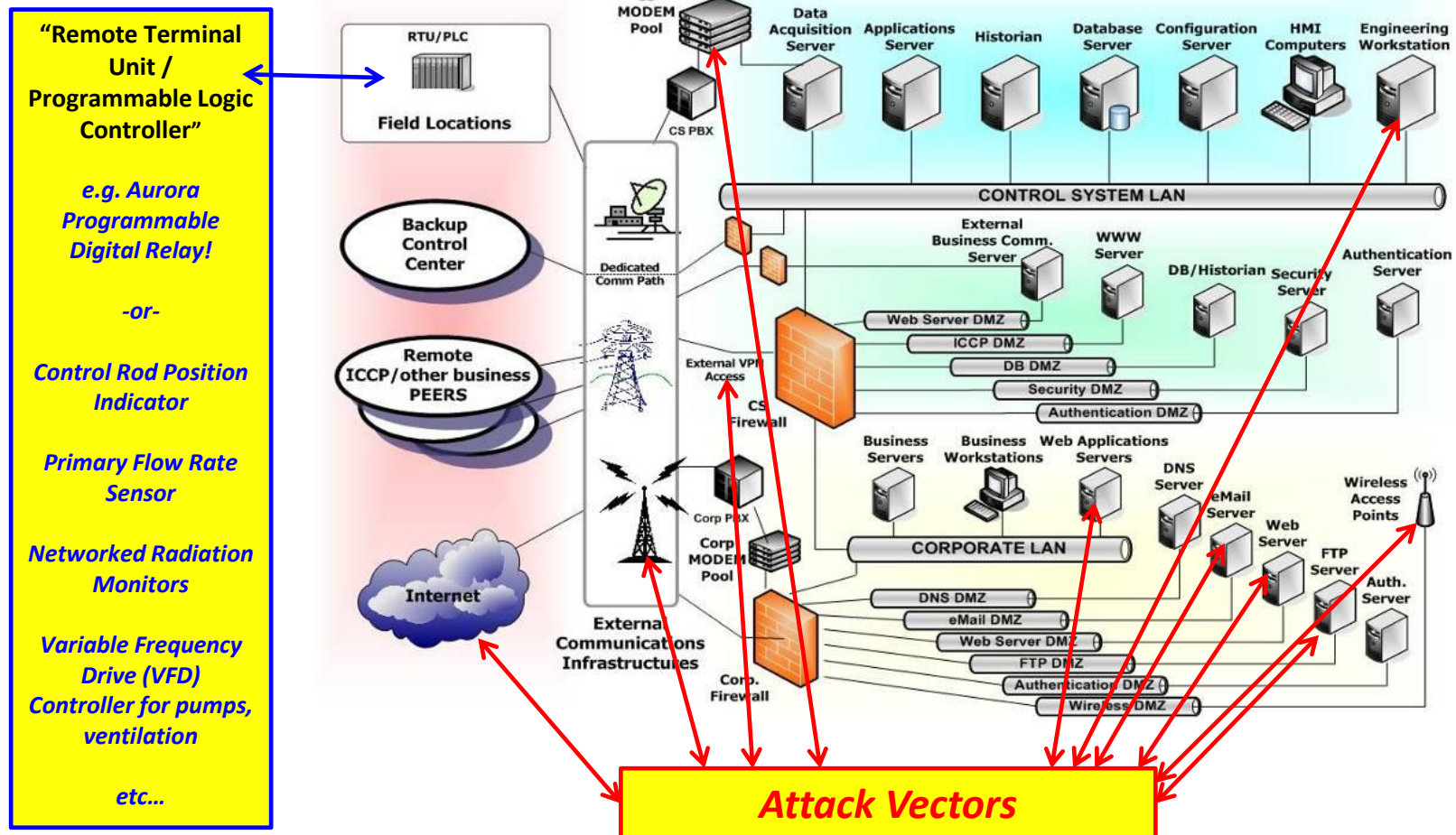
- Idaho National Laboratory ran the Aurora Generator Test in 2007 to demonstrate how a cyber attack could destroy physical components of the electric grid.
- The experiment used a computer program to rapidly open and close a diesel generator's programmable circuit breakers out of phase from the rest of the grid and cause it to explode.
- This vulnerability is especially a concern because much grid equipment supports using Modbus and other [legacy communications protocols that were designed without security in mind](#). As such, they don't support authentication, confidentiality, or replay protection, which means any attacker that can communicate with the device can control it.



<https://www.youtube.com/watch?v=LM8kLaJ2NDU>

Cyber-Security for Nuclear ICS

SCADA: “Supervisory Control And Data Acquisition” Network Architecture



Cyber-Security for Nuclear ICS

Common Cyber Attack Vectors

- ❑ Wireless Capable devices
 - printers, cameras, “Internet-of-Things” devices, etc. increase attack surface
- ❑ Removable Media & Mobile Devices
 - USB/CD/DVD, flash media, laptops, smart phones, etc.
- ❑ Business networks not isolated from Operational ICS network.
- ❑ Supply Chain / Vendors
 - Equipment procurement
 - Software updates or patches



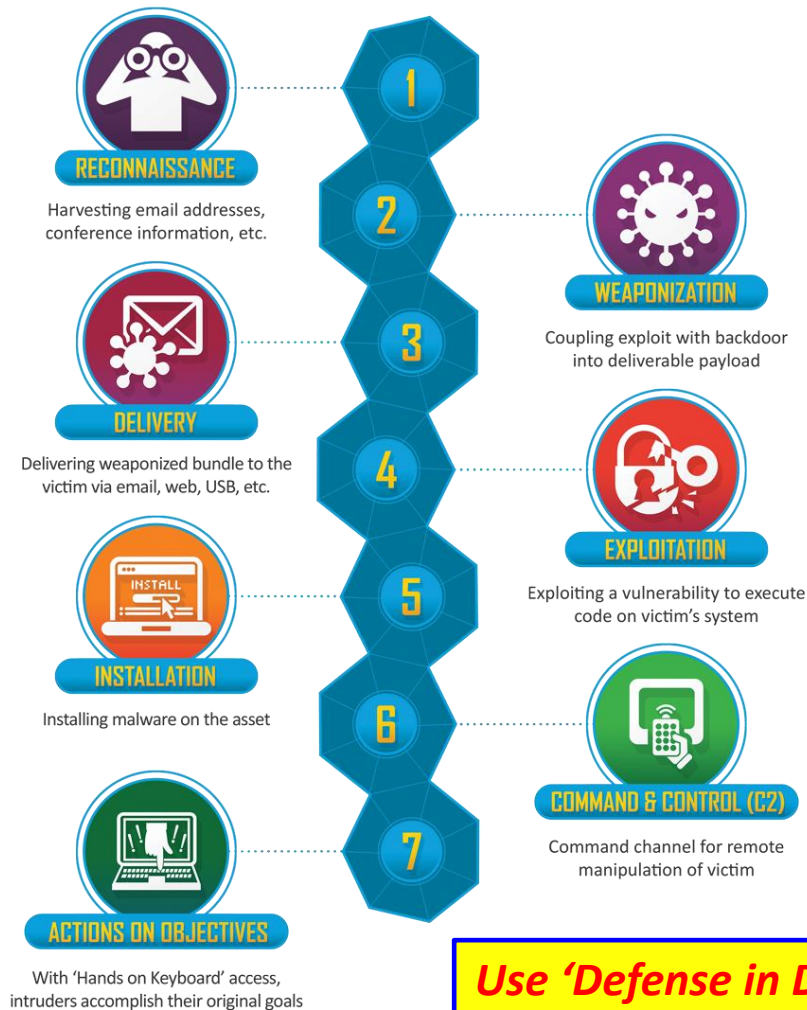
Cyber-Security for Nuclear ICS

Common Attack Delivery Methods

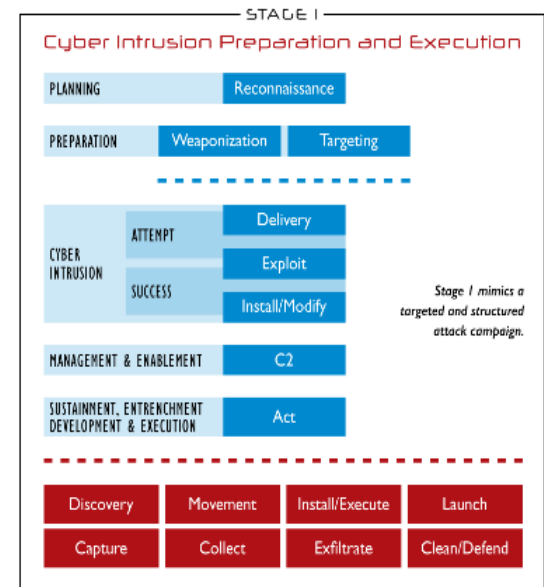
Many ICS-related attacks use unsophisticated methods of delivery:

- **Phishing** – A deceptive email designed to trick the recipient into disclosing sensitive information, usually account access credentials
- **Spear phishing** – A phishing email using targeted information designed specifically for the recipient.
- **“Whaling”** - A spear phishing attack targeting an executive with access to sensitive corporate information.
- **Watering hole attack** – Delivery of malware through a seemingly legitimate web site. Either a deceptive link is provided to a user, often through phishing or a legitimate website can be hacked.

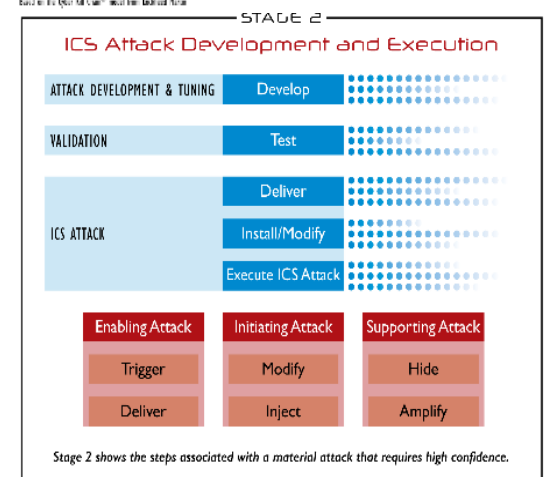
Cyber “Kill Chain”



Use 'Defense in Depth' to Disrupt the Kill Chain!



Based on the Cyber Kill Chain® model from Lockheed Martin



Cyber-Security: Defense In Depth

❑ Cyber-Security Culture:

- **Policies** – Management Commitment to Cyber-Security
- **Procedures** – ****CDA (Critical Digital Asset) Audit****, Password Management, Least Permissions, Vendor access, Firewall Rules, Air Gap/Flash Media control, Configuration/Settings Backups, Recovery from Attack
- **Training** - Procedures, Cyber Hygiene, Cyber-Awareness – e.g. Spear Phishing, Social Media (LinkedIn, Facebook)

❑ Hardware Solutions:

- Network Zones, Data Diodes, Intrusion Prevention Systems (IPS), Unified Threat Management (UTM), VPN, Air-Gapped ICS sub-networks, Design Simplification!!

❑ Software Solutions:

- Software Control (*remove unused modules/drivers which may provide vulnerabilities and attack vectors*), **Whitelisting**, Network scanning tools, Encryption, Anti-virus, install software updates and patches that will mitigate CVEs (Common Vulnerability Exposures) without compromising operation of the ICS networks.

Cyber Security Assessment Methodology

1. Perform an Audit of Facility CDA and Cyber Security Hygiene:

- Create an Inventory facility CDA
- Determine Connectivity, Configuration, and Software Vulnerabilities for each CDA
- Trace CDA Network Maps, Interdependencies & level of Physical Protection
- Evaluate Facility Cyber-Security Culture, Hygiene, Procedures, and Training.

2. Using the Audit results, perform a Cyber Security Risk Assessment of CDA:

- Evaluate Potential Attacker Threats:

$$\underline{\textit{Threat} = \textit{Capability} + \textit{Intent} + \textit{Opportunity}}$$



Tenet of OPSEC
"Operations Security"

- Assess Vulnerability of CDAs to attack.

$$\underline{\textit{Vulnerability} = \textit{CVE/Exploits} + \textit{Network Vectors} + \textit{Interdependencies}}$$

- Determine the Consequences of a successful cyber-attack on each CDA.

3. Rank Risk and Prioritize Mitigation:

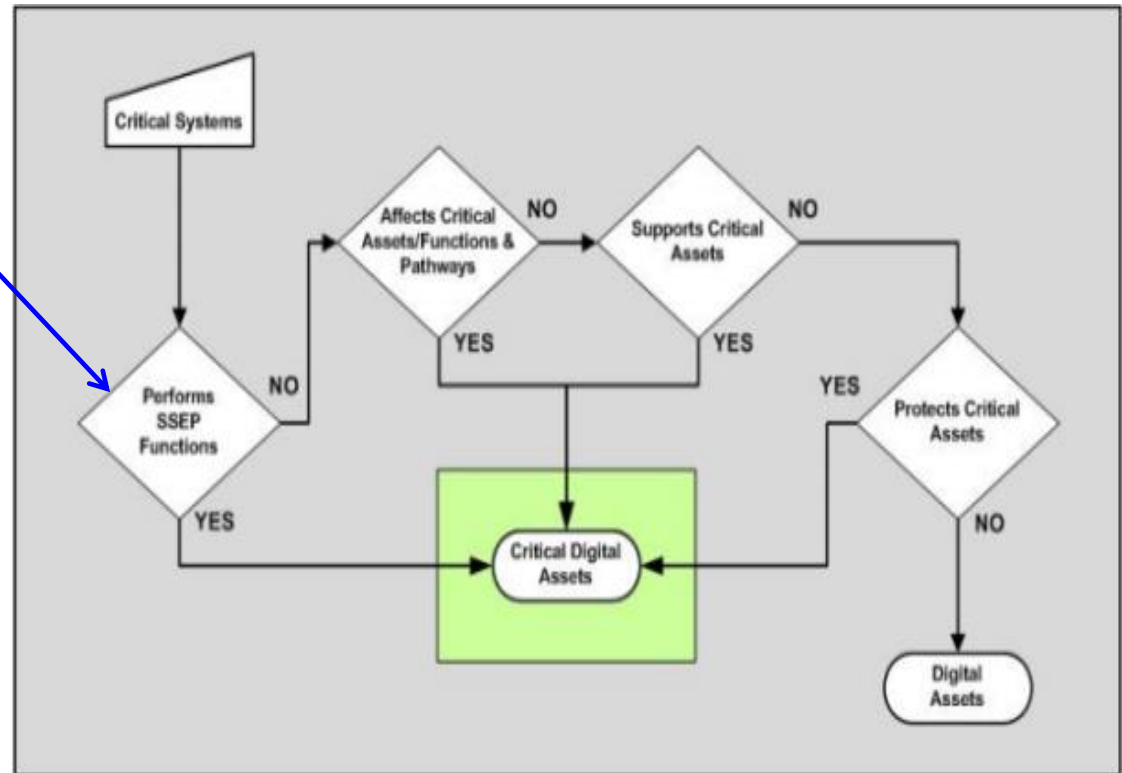
$$\underline{\textit{Risk Index} = \textit{Threat} \times \textit{Vulnerability} \times \textit{Consequence}}$$

Reactor Industrial Control System (ICS)

Identify and Audit Critical Digital Assets (CDA)

SSEP: “Safety, Security, Emergency Preparedness” Functions

- Reactor safety and operational control.
- Physical security of the facility including personnel access monitoring and control.
- Detection of unsafe/unauthorized conditions.
- Emergency response/communications
- Storage and protection of Safe Guarded Information (SGI).
- Accurate inventory/location of nuclear materials.



“Critical Digital Assets” (CDA)

- VS -

non-critical digital assets (e.g. IT assets)

Assessment Methodology – CDA Audit

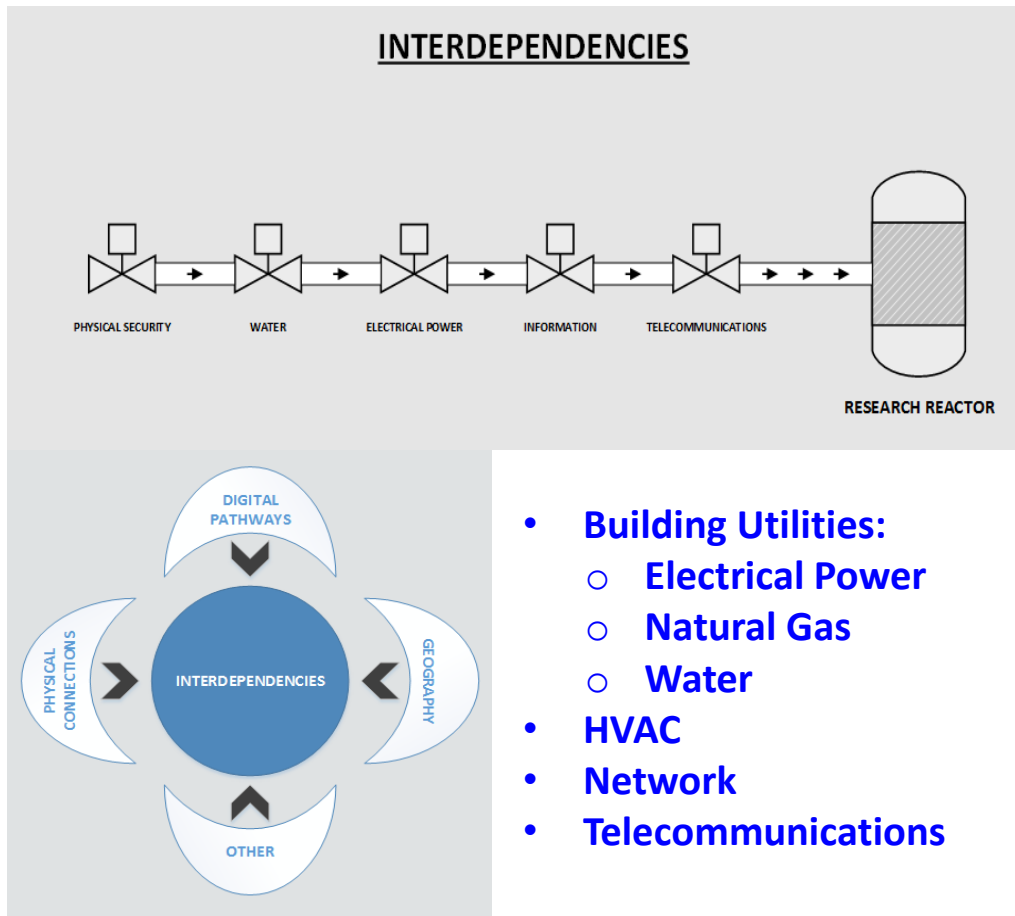
CDA Inventory and Audit:

- i. Inventory** - Create listing of Reactor ICS CDA.
- ii. CDA Configuration Information:**

Model, vendor, operating system and application software, software updates, settings/configuration data, accounts/user IDs/passwords (defaults used?)
- iii. Physical Protection of CDA** – Is it inside or outside the secured area? In a locked cabinet?
- iv. Information Published** - Are schematics or detailed descriptions of facility systems available on the facility website, in publications, or in publicly available educational materials?
- v. CDA Interdependencies** – Functioning dependent on building utilities (water, electric, gas, HVAC) and telecommunication or network services?

Assessment Methodology – CDA Audit

Audit CDA Interdependencies:



Service Provider Audit Form:

- [Availability Requirements](#)
- [Fully or Partially met?](#)

EXTERNAL INTERDEPENDENCY DOCUMENTATION			
SYSTEM INFORMATION			
System Name:			
System Description:			
System Owner:		Contact Information:	
INTERDEPENDENCY INFORMATION			
CATEGORY	SERVICE PROVIDER INFORMATION		
☐ Physical Connections	Company Name:		
☐ Digital Pathways	Address:		
☐ Geographic	Telephone Number:		
☐ Other	Contact Person:		
Service Provider:		REQUIRED CONDITIONS	
☐ Can Fully Meet Conditions			
☐ Can Partially Meet Conditions			
☐ CANNOT Guarantee Conditions			
Service Provider:		Contact Individual:	
IN CASE OF EMERGENCY			
Required Actions:			

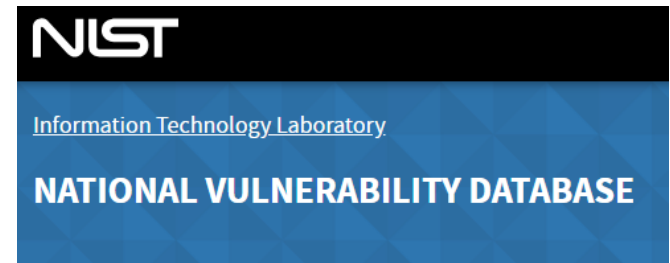
Assessment Methodology – CDA Audit

Audit Application and Operating Software Vulnerabilities:

a) National Institute of Standards (NIST) National Vulnerability Database (NVD) –

Check for known exploits specific to each CDA. Search for **Common Vulnerability and Exposures (CVE)** software issues.

- i. [Common Vulnerability Scoring System \(CVSS\)](#)
- ii. [Attack Complexity](#)
- iii. [Access Complexity](#)



b) DHS ICS-CERT 'Control Systems Advisories and Reports' Databases

Check for specific alerts and advisories related to facility CDA operating and application software, including CVE:

- i. [Attack Difficulty](#)
- ii. [Vulnerability Impact](#)
- iii. [Vulnerability Characterization](#)
- iv. [Mitigation Tools](#)



Assessment Methodology – CDA Audit

NIST National Vulnerability Database

The Vulnerability Scoring Index (VSI) is being assessed for the operation and application software installed on each CDA utilizing the NIST National Vulnerability Database at <https://nvd.nist.gov/>.

The screenshot shows the NIST National Vulnerability Database (NVD) search interface. The header includes the NVD logo, 'Computer Security Resource Center', 'National Vulnerability Database', and the NIST logo with 'National Institute of Standards and Technology' and 'U.S. Department of Commerce'. A navigation bar contains links for General, Vulnerabilities, Vulnerability Metrics, Products, Configurations (CCE), Info, Other Sites, and a Search button. Below the navigation bar, the page title is 'Search Vulnerability Database'. A note states: 'NOTE: Only vulnerabilities that match ALL keywords will be returned, Linux kernel vulnerabilities are categorized separately from vulnerabilities in specific Linux distributions'. The search form includes fields for Keyword Search, CVE Identifier, Category (CWE), CPE Name, Vendor, and Product. It also has radio buttons for Search Type (Basic, Advanced) and Results Type (Overview, Statistics). There are date range selectors for Published Date Range and Last Modified Date Range, each with Start Date and End Date dropdowns. A 'Search' button and a 'Reset' button are present. A 'Contains Hyperlinks' section has checkboxes for US-CERT Technical Alerts, US-CERT Vulnerability Notes, and OVAL Queries.

The National Vulnerability Database search engine is a powerful tool that allows the user to enter detailed search parameters looking for Common Vulnerabilities and Exposures (CVE) or Common Platform Enumerations (CPE) for each audited CDA.

Challenges: Learning curve for correctly applying and utilizing the search engine!

Assessment Methodology – CDA Audit

ICS-CERT Advisories and Alerts Database



The screenshot shows the ICS-CERT website. At the top is the U.S. Department of Homeland Security logo and the ICS-CERT name. Below is a navigation bar with links: HOME, ABOUT, ICSJWG, INFORMATION PRODUCTS, TRAINING, and FAQ. On the left is a sidebar menu under 'Control Systems' with links: Home, Calendar, ICSJWG, Information Products, Training, Recommended Practices, Assessments, Standards & References, Related Sites, and FAQ. The main content area features a heading 'The Industrial Control Systems Cyber Emergency Response Team (ICS-CERT)' followed by a paragraph describing the team's mission. Below this is a 'Sign-Up for GovDelivery: Product Notices Direct to Your Inbox!' section. At the bottom, there are two sections: 'Alerts' and 'Advisories', each with a warning icon and a brief description.

Control Systems

- Home
- Calendar
- ICSJWG
- Information Products
- Training
- Recommended Practices
- Assessments
- Standards & References
- Related Sites
- FAQ

The Industrial Control Systems Cyber Emergency Response Team (ICS-CERT)

The Industrial Control Systems Cyber Emergency Response Team (ICS-CERT) works to reduce risks within and across all critical **infrastructure** sectors by partnering with law enforcement agencies and the intelligence community and coordinating efforts among Federal, state, local, and tribal governments and control systems owners, operators, and vendors. Additionally, ICS-CERT collaborates with international and private sector Computer Emergency Response Teams (CERTs) to share control systems-related security incidents and mitigation measures.

 Learn More about ICS-CERT

Sign-Up for GovDelivery: Product Notices Direct to Your Inbox!

Control Systems Advisories and Reports

 **Alerts**
Alerts provide timely notification to critical infrastructure owners and operators concerning threats to critical infrastructure networks.

 **Advisories**
Advisories provide timely information about current security issues, vulnerabilities, and exploits.

Industrial Control Systems (ICS) – Cyber Emergency Response Team (CERT):

<https://ics-cert.us-cert.gov/>

Alerts Database - threats to critical infrastructure networks

Advisories - current security issues, vulnerabilities and exploits

CHECK 'EM OUT!

Assessment Methodology – Network Audit

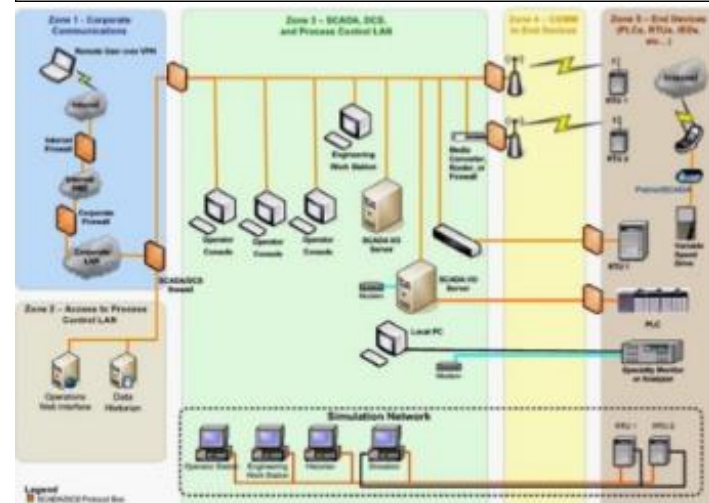
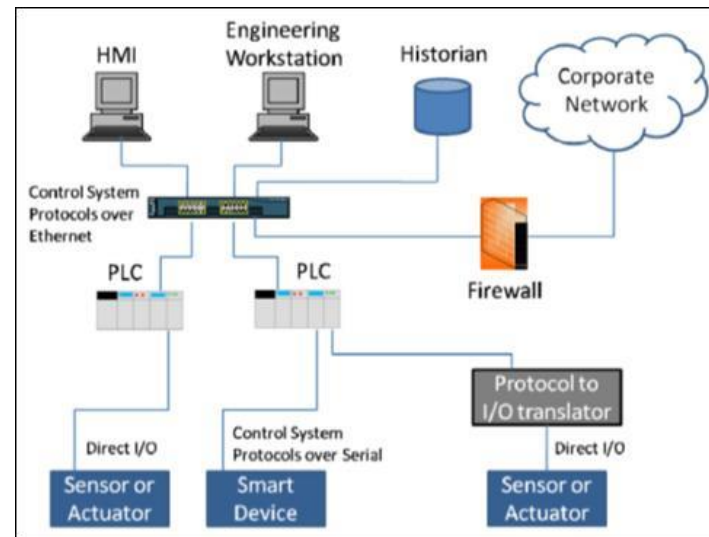
Audit ICS Network Configuration:

1. Determine device communication protocols:

- Connected to a LAN? Air gapped?
- Remote connectivity - Wifi or Bluetooth? Enabled or disabled?

2. Trace Network Maps:

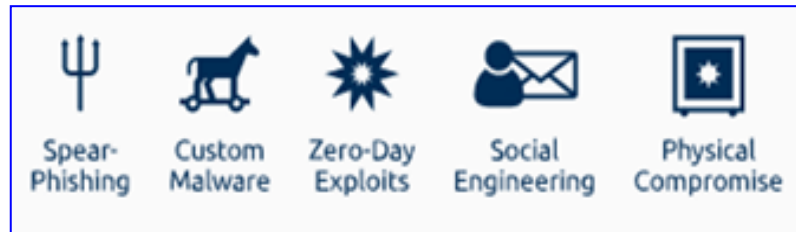
- Map local network architecture: ICS hardware components, network switches and routers, network addresses.
- Are network zones utilized and maintained? Firewalls, virtual private networks (VPN), data diodes?



Assessment Methodology – Audit

Audit Institutional Cyber-Security Policies and Procedures:

Evaluate existing institutional cyber-security culture, policies, procedures and training as applied to reactor ICS



- i. **Policy** – A policy statement formalizing management commitment to implementing effective cyber security practices.
- ii. **Procedures** – password administration, ‘least permissions’, configuration settings, maintenance of firewalls or VPN, disabling unneeded wireless communication functionality, effective air gapping requirements and scanning of portable media, a trusted vendor program, encryption requirements for digital SGI, incident response and reporting, performing periodic audits.
- iii. **Training** - introductory and refresher training in procedures, good cyber-hygiene practices, phishing awareness, proper use of social media (e.g. LinkedIn, Facebook).

Assessment Methodology – Evaluate Threat Metrics

Attacker Capability:

Defined as the means or resources the attacker would require to carry out an attack, including needed skills, expertise, knowledge, money & tools.

For the purpose of this assessment, the availability of certain [exploitation tools](#) or [malware](#) will be utilized to assess attacker capability. Any identified release of exploitation tools (e.g. targeting specific PLCs) or ICS focused malware obtained in the review of the [ICS-CERT 'Alerts' database](#) is applicable to setting this metric.

Attacker Capability Index (ACI):

<u>ACI</u>	<u>Parameter</u>
1	Low - No exploitation tools or malware identified that could impact facility ICS or CDA.
2	Medium - Exploitation tools or malware identified that could generally impact facility ICS.
3	High - Specific exploitation tools or malware identified that could impact specific CDA.

Assessment Methodology – Evaluate Threat Metrics

Attacker Intent:

Defined based on whether emerging threats, or an identified increase in activities by malicious groups, including hacktivist or anarchist groups, have been identified as targeting CDA.

The data obtained in the review of the ICS-CERT 'Alerts' database is applicable to setting this metric. The [Alerts database is reviewed to determine if any emerging threats or activities have been identified that generally target ICS infrastructure, or that target the specific type\(s\) of facility CDA.](#)

Attacker Intent Index (AII):

<u>AII</u>	<u>Parameter</u>
1	Low – No Emerging threats identified; no identified increase in activities by malicious groups, including hacktivist or anarchist groups, targeting ICS infrastructure or specific type of CDA.
2	Medium - Emerging threat(s) identified general to ICS infrastructure; identified increase in activities by malicious groups, including hacktivist or anarchist groups, generally targeting ICS infrastructure.
3	High – Emerging threat(s) identified specific to CDA; identified increase in activities by malicious groups, including hacktivist or anarchist groups, targeting specific type of CDA.

Assessment Methodology – Evaluate Threat Metrics

Attacker Opportunity:

Defined as the set of conditions that need to be met for an adversary to be confident their attack will be successful.

Opportunities are related to the exposure and vulnerability of targets. This can be related to the level of physical access an adversary has to a CDA target, as well as access to specific knowledge about the system.

Attacker Opportunity Index (AOI):

AOI	Parameter
1	Low - Must meet all of the following criteria: i) Physical access to the CDA is restricted (i.e. it is in a secured cabinet or room) and communication port locks are installed. ii) Specific information about CDA, including model numbers and system descriptions or schematics, are not published or available online. iii) Effective cyber hygiene practices are in place, and the facility implements official cyber security policies, procedures and training.
2	Medium - Must meet all of the following criteria: i) There is limited or intermittent physical access to CDA, or communication port locks are not installed. ii) Limited specific information about CDA may be published or available online. iii) "Ad hoc", unofficial, or otherwise limited cyber hygiene practices, policies, procedures, and/or training are in place.
3	High - Conditions that do not meet requirement given for 1 or 2 above.

Assessment - Evaluate Vulnerability Metrics

Network Protection Index:

Determine whether a CDA connected to a network or air gapped is well protected from unauthorized network access.

This is a function of the network configuration and procedural network security measures that are in place.

Network Protection Index (NPI):	
NPI	Parameter
1	Low: Must meet all of the following criteria: i) CDA has either a) no local or remote digital connectivity, b) is effectively air gapped with commensurate procedural controls, or c) has ≥ 2 levels of maintained network protection (i.e. firewalled zones not including enterprise firewall, VPN, etc...). ii) No capability for portable media and mobile devices (PMMD) or media capability is “controlled” (scanned, secured, maintained, etc.). iii) Robust password protections are in place in accordance with the device capability and are regularly changed, maintained, or updated. Least permissions access restrictions employed where supported.
2	Medium: Must meet all of the following criteria: i) CDA is functionally air-gapped (e.g. no LAN/Wifi connection, but without PMMD scanning infrastructure) or isolated from public network via at least one maintained firewall that is not the enterprise firewall. ii) Passwords or passcodes in use, with no defaults enabled or used.
3	High: All other assets that do not meet requirement given for 1 or 2 above.

Assessment - Evaluate Vulnerability Metrics

Vulnerability Scoring Index:

Review the “Common Vulnerability Exposures” (CVE) obtained from the DHS ICS-CERT ‘Control Systems Advisories and Reports’ databases and the NIST National Vulnerability Database search engine.

The version of the operating system software, whether it is updated automatically, and whether antivirus protection is active also inform this metric.

Vulnerability Scoring Index (VSI):

<u>VSI</u>	<u>Parameter</u>
1	Operating System Software (For PC/workstation based CDA): Current supported OS version installed and automatically or actively updated – OR – if automatic updates are disabled, whitelisting software is installed and maintained; antivirus software is installed, enabled, and actively updated. - AND - Application Software or Firmware: <u>No</u> CVE’s identified for installed software versions.
2	Operating System Software (For PC/workstation based CDA): Current supported OS version installed but <u>not</u> automatically updated and whitelisting software <u>is not</u> installed or maintained; antivirus software is installed, enabled, and actively updated. - AND - Application Software or Firmware: ≤ 3 CVE identified for current version with maximum associated Common Vulnerability Scoring System (CVSS) Base Score(s) ≤ 6.9.
3	Conditions that do not meet the requirements given for 1 or 2 above.

Assessment - Evaluate Vulnerability Metrics

Interdependency Vulnerability Index:

Review the interdependencies identified and documented during the audit to inform this metric.

Interdependency Vulnerability Index (IVI):	
IVI	Parameter
1	Low: Meets <u>one or more</u> of the following criteria: i) The service provider can '<u>Fully Meet the Conditions</u>' required in order to support the interdependent service or function under all conditions. ii) Redundant backups exist that fully mitigate any loss of service from the provider (e.g. backup generator providing electrical power, cell phone communication -vs- land line, backup parallel network connection, emergency water supply, etc...). iii) Loss of service results in CDA or SSEP system defaulting to a fail-safe condition relative to the associated consequence metric.
2	Medium: Meets <u>one or more</u> of the following criteria: i) The service provider can '<u>Partially Meet the Conditions</u>' required in order to support the interdependent service or function, or only under limited conditions. ii) Redundant backups exist that only partially or temporarily mitigate any loss of service from the provider (e.g. backup generator providing limited electrical power, limited communication backup, etc...)
3	High: All other interdependencies that do not meet the requirements given for 1 or 2 above.

Assessment – Evaluate Consequence Metrics

Consequence Index:

Consequence Index (CI):	
<u>CI</u>	<u>Parameter</u>
1	Low Level Consequence – Attack on experimental facilities or non-safety related equipment causing administrative burdens, including theft or corruption of experimental data or safeguarded documents.
2	Medium Level Consequence – Attack on experimental facilities or auxiliary systems resulting in potential loss of service, loss of control, or damage to equipment.
3	High Level Consequence – Attack on safety related (e.g. SSEP) equipment, instrumentation, or radiation monitoring system resulting in an increased probability of radiation exposure or injury to personnel.
4	Critical Level Consequence – Attack on reactor control or emergency systems (e.g. SSEP) resulting in an elevated probability of a loss of control, of damage to reactor systems, of potential diversion of radioactive material, or an uncontrolled release offsite.

The consequences of a successful cyber-attack on NPR CDA would vary from low to severe depending on the function of the reactor ICS as determined during the audit.

Risk Assessment

Rank Risk and Prioritize Mitigation:

The Risk Index (RI) may be determined as follows:

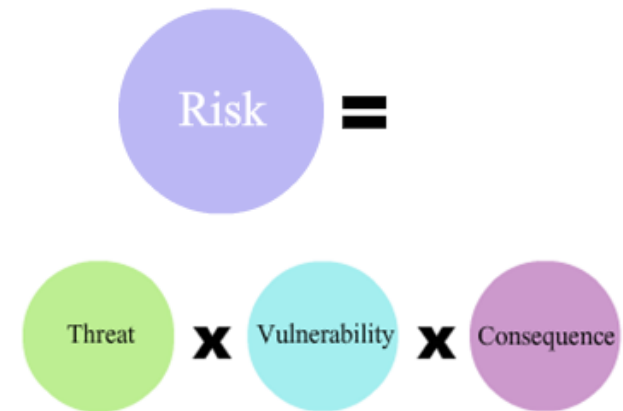
Threat Index (TI) = ACI + AII + AOI

Vulnerability Index (VI) = NPI + VSI + IVI

Risk Index (RI) = [TI x VI x CI]/C

where C is a normalizing constant.

The larger the Risk Index value, the larger the associated risk of a successful cyber-attack on the CDA and systems evaluated.



Risk Index (RI):

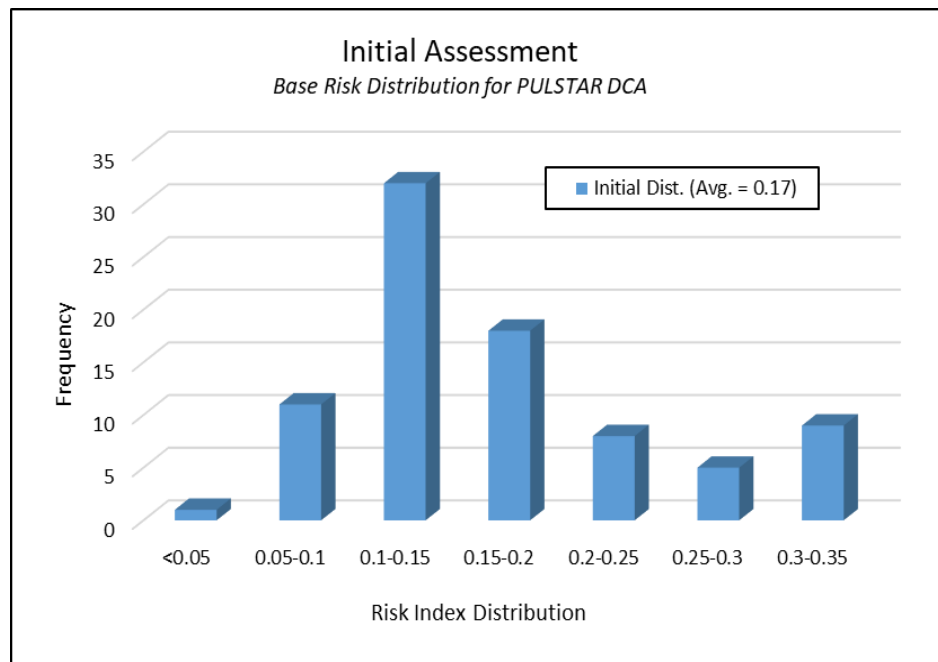
RI ≥ 0.5	Highest Priority for Mitigation.
$0.5 > \text{RI} \geq 0.25$	Medium Priority for Mitigation.
RI < 0.25	Lowest Priority for Mitigation.

Case Study

PULSTAR ICS Initial Risk Assessment Results

Reactor ICS Assessment Outcomes:

- 84 separate CDA were identified, audited and reviewed.
- On-line experimental systems had initial RI values of up to **0.35**
- All reactor control and safety related ICS had initial RI values of ≤ 0.25
- More than **17,000 CVE were found** for CDA operating systems and application software.
- Many workstations/CDA running outdated operating systems or firmware.
- “Air gaped” systems only nominally protected. No air gap infrastructure.
- Significant level of reactor ICS information published, increasing attacker opportunity.



Physical Security System Assessment Outcomes- Areas for Improvement:

1) hardening access reader hardware, 2) upgrading server infrastructure (separating security functions on virtual machines), and 3) updating procedural requirements (authentication of authorized users).

Nuclear Industry Vulnerability Trends

Multiple trends within the nuclear industry are driving increased vulnerability to attack

- ☐ Automation and digital attack surface is growing
- ☐ Information about employees, infrastructure and processes publically available on internet
- ☐ Increasing use of wireless technologies
- ☐ High propagation of foreign-made equipment in power industry
- ☐ Cybersecurity education for all employees is not a priority.
- ☐ “Over-functionality” of digital equipment – No way to remove unused hardware and code which may provide vulnerabilities and attack vectors

Historic Nuclear Cyber Attacks (1)

Davis Besse

- Details
 - 2003 – Davis Besse in Ohio
 - Slammer Worm spanning corporate and control networks
- Impact
 - Complete shutdown of digital portion of Safety Parameter Display System (SPDS) and Plant Process Computer (PPC) for 5 hours.
- Lesson
 - Firewalls do not provide invincibility for control systems from cyber threats

Hatch Plant Patch

- Details
 - 2008 at Hatch nuclear plant in Georgia
 - Software update on business network system reset data on control system and impacted safety systems
- Impact
 - Automated safety systems at the plant triggered a shutdown
- Lesson
 - Dangers of two-way communication from corporate networks to control networks. Control systems should be isolated from corporate networks

Historic Nuclear Cyber Attacks (2)

Stuxnet

- Details
 - 2010 at Natanz Iranian Enrichment Facility
 - **Malicious worm** targeted PLCs
 - Network isolation bypassed
- Impact
 - **destroyed $\approx$ 1,000 uranium enriching centrifuges**
 - **$\approx$ 30% decrease in enrichment efficiency**
- Lesson
 - Proved possibility that sophisticated malware could target air-gapped control systems and nuclear facilities.

Phishing Operators

- Details
 - 2014 at Korea Hydro and Nuclear Power (KHNP) in South Korea
 - 6,000 phishing emails containing malicious code sent to 3,500 employees
- Impact
 - **Confidential Information Leaked including personal details of 10,000 employees and reactor designs and manuals**
- Lesson
 - **Phishing remains effective and can be well-crafted**

Recent Nuclear Cyber Attacks

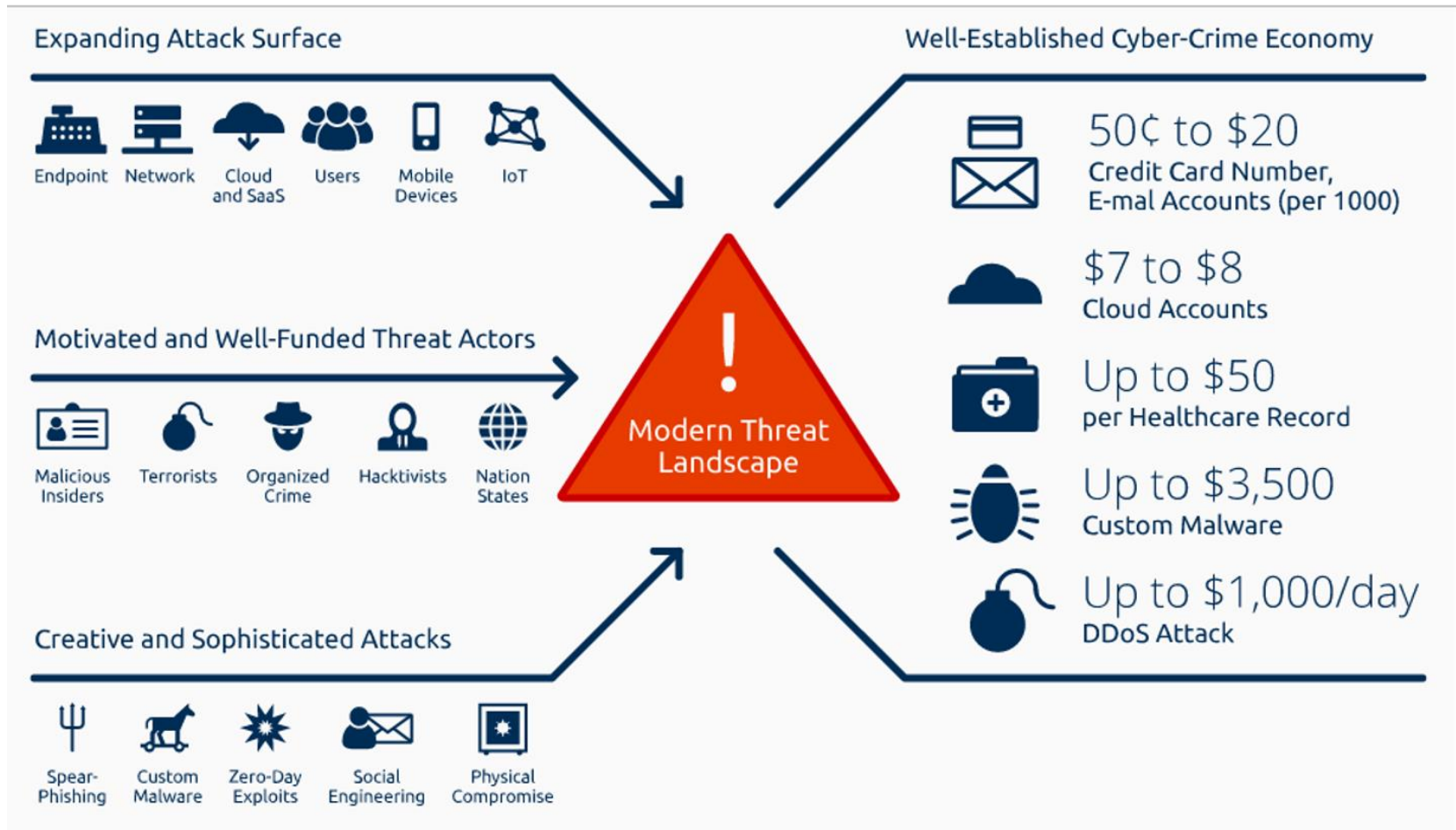
Virus at NPP

- Details
 - 2016 at Gundremmingen nuclear plant in Germany
 - W32.Ramnit and Conficker Viruses
- Impact
 - Found on 18 removable data drives
 - Found in office computers systems
 - No damage to operational network
- Lesson
 - **Confirms USBs as a likely attack vector** for nuclear facilities

Nuclear 17

- Details
 - June 2017 at a US nuclear power plant and other utilities and energy related entities
 - Fake resumes with executable code
 - Targeted senior control engineers
- Impact
 - **Corporate network compromised via spearphishing emails**
 - **Redirected internet traffic through attacker's machines**
- Lesson
 - **Phishing remains effective**
 - **Watering Hole attacks are often used in conjunction with phishing attacks.**

Continuously Evolving Cyber Threat Landscape



Summary

- ❑ Safety is key and nuclear is not immune
 - ❑ Common cyber security attacks include phishing, spear phishing, and watering hole attacks
 - ❑ Tools are available to help identify security issues and vulnerabilities
-
- Homework 4 and Homework 5 both due next week.
 - Lab on Thursday!